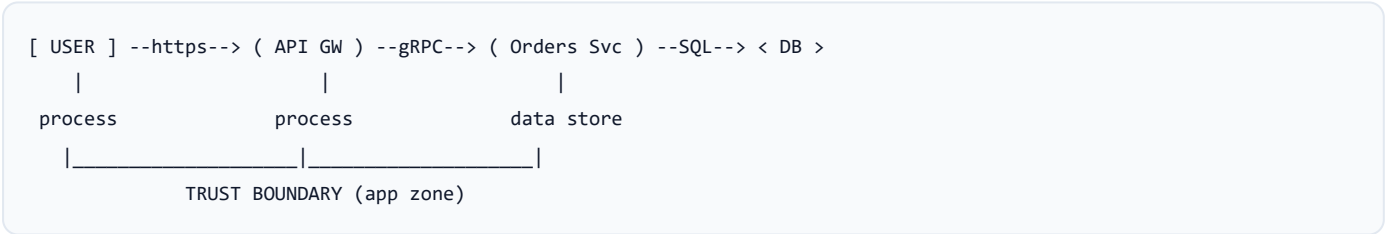


Threat Modeling in Practice: STRIDE + DFD

The workflow

- Scope – what component boundary?
- Enumerate assets
- Create data-flow diagram (DFD) – processes, data stores, trust boundaries
- Apply STRIDE per element
- Rank & record – risk score + mitigation + owner

Data-flow diagram conventions



- Circles/roundrects = processes
- Open rectangles = external entities (user, third party)
- Double edges or store symbol = data stores
- Dashed line = trust boundary

STRIDE scoring template

#	Threat	STRIDE	Likelihood (1-5)	Impact (1-5)	Risk	Mitigation
1	Attacker replays order via missing idempotency	R	4	4	16	Idempotency keys

#	Threat	STRIDE	Likelihood (1-5)	Impact (1-5)	Risk	Mitigation
2	SQL injection in search	T/I	3	5	15	Parameterized queries
...	...	...				

Common pitfalls

- Not crossing trust boundaries (where input arrives is where bugs live)
- Forgetting the "deny by default" angle of STRIDE (E)
- Drowning in detail – model the decision-critical flows
- No owner assigned → findings die

Tooling

- OWASP Threat Dragon (free) – DFD + STRIDE notes
- Microsoft Threat Modeling Tool (Windows) – templates
- PyTM / threatspec – as-code models you can version

A practical threat model is one your team can RE-READ. Keep the artifact: an attacker-relevant statement of how the system acts when attacked.